





HireLink

Cahier des charges — version 5.1

Plateforme bilatérale de gestion du recrutement (ATS)

Spécification fonctionnelle et technique — document de référence
Toute exigence décrite ici est traçable dans le code livré (section 9).

Rubrique	Valeur
Établissement	ENSA Tétouan — Université Abdelmalek Essaâdi
Filière	Génie Informatique (GI) — Semestre 5
Module	Frameworks et Technologies Web
Réalisé par	EL ASSAL Douae
Projet	HireLink — ATS français pour PME marocaines
Date	7 novembre 2026
Version du document	5.1
Backend	Spring Boot 3.3 / Java 21 — http://localhost:8081/api/v1
Frontend	HTML, CSS et JavaScript statiques — http://localhost:5500
Base de données	MariaDB 10.4.32 — schéma hirelink, 26 tables

Sommaire

Numérotation stable : EF = exigence fonctionnelle, EN = exigence non fonctionnelle, R = règle de gestion, GO = objectif, RQ = risque. Repère de lecture : la section 9 relie chaque EF à un fichier et à une ligne du dépôt.

§	Titre	Contenu
1	Contexte et problématique	1.1 terrain, 1.2 question, 1.3 réponse produit, 1.4 périmètre technique
2	Objectifs et périmètre	GO-01 à GO-09, ce qui est dans le périmètre, ce qui n'y est pas
3	Acteurs et personas	rôles, six personas, matrice des droits réels, comptes de démonstration
4	Exigences fonctionnelles	EF-01 à EF-81 regroupées en neuf modules
5	Règles de gestion	R01 à R16 et RM01 tels qu'écrits dans le code, plus onze règles RG-nn
6	Exigences non fonctionnelles	EN-01 à EN-34 : sécurité, performance, exploitation, ergonomie, RGPD
7	Modèle de données	26 tables, relations, énumérations et vocabulaires contrôlés
8	Parcours fonctionnels	six parcours pas à pas, avec le point d'observation
9	Matrice de traçabilité	EF → fichier:line → preuve observable
10	Planning, risques, limites, glossaire	séances, RQ-01 à RQ-10, annexes

1. Contexte et problématique

1.1 Le terrain observé

Le recrutement dans les PME marocaines se pratique encore par boîtes aux lettres. Une annonce est publiée sur un ou deux sites, les candidatures arrivent en pièces jointes, la sélection se fait dans un classeur, et l'état d'une candidature n'est connu que de celui qui a ouvert le fichier.

Les logiciels de suivi de candidature existants sont presque tous étrangers (Workable, Greenhouse, SmartRecruiters, Teamtailor). Ils sont facturés par siège et dans une devise non locale, leur contrat d'entrée de gamme se situe autour de 30 à 100 € par siège et par mois, et ils supposent un processus de recrutement déjà formalisé. Une entreprise de moins de cinquante salariés n'y a pas accès.

Le second constat concerne les candidats. Les petites annonces non contrôlées restent un canal de fraude : demandes de frais d'inscription, fausses offres de télétravail, entreprises sans existence légale vérifiable. Un candidat ne dispose d'aucun moyen, dans les outils grand public, de distinguer une société immatriculée au registre marocain d'une coquille vide, ni de savoir ce que sa candidature est devenue.

Tableau 1.1 — Ce qui pose problème, et ce que le problème produit comme exigence

Constat	Effet mesurable	Exigence qui en découle
Candidatures dispersées en e-mail	Aucun état partagé entre RH, manager et candidat.	Un dossier unique, un pipeline explicite, un historique append-only.
Coût des ATS étrangers	Licence en euros par siège ; engagement annuel.	Un produit utilisable sans licence, avec des formules tarifées en dirhams.
Opacité pour le candidat	Aucune réponse, ou une réponse après plusieurs semaines.	Suivi interne du délai pour le recruteur et rythme réellement mesuré pour le candidat.
Offres frauduleuses	Perte de temps, quelquefois perte d'argent.	Contrôle du contenu des annonces et identification de l'entreprise avant publication.
Décisions non tracées	Impossible d'expliquer un refus, donc d'améliorer le process.	Motif de refus obligatoire pris dans un catalogue, conservé dans l'historique.
Comparaison de candidats subjective	Le dossier est jugé sur le nom ou l'école.	Score de compatibilité calculé sur des critères déclarés, figé à la candidature, et prompts d'aide sans données d'identité.

1.2 Problématique

Comment une PME marocaine peut-elle conduire un recrutement complet — publication vérifiée, réception des candidatures, pipeline, entretien, décision motivée et tracée — sans licence étrangère, sans exposer le candidat à une annonce non contrôlée, et en donnant au candidat une information honnête et vérifiable sur le traitement de sa candidature ?

Le mot « honnête » est opérationnel ici : une information n'est affichée au candidat que si elle est produite par une donnée mesurée dans la base, jamais par un texte promis. Cette position conditionne plusieurs choix décrits en sections 4, 5 et 6.

1.3 Réponse réellement portée par l'application

Six mécanismes portent la promesse « recrutement à performance équitable ». Chacun est décrit avec son pendant absent, pour que la promesse ne dépasse pas le produit.

Tableau 1.2 — Promesse, mécanisme codé, limite acceptée

Promesse	Mécanisme réellement en place	Limite assumée
Le recruteur est tenu par un délai interne	job_offers.response_sla_days ; deadline calculée à la candidature (applications.response_deadline) ; SlaMonitorService, exécuté toutes les 30 minutes, notifie l'auteur de l'offre et le responsable du poste assigné.	Le délai n'est pas affiché au candidat : le champ reste un simple suivi interne, comme l'indique le commentaire du DTO (ApiDtos, responseSlaDays).
Le candidat voit un rythme, pas une promesse	ResponsivenessService : médiane du premier recruteur-réponse sur 180 jours, minimum trois dossiers répondus ; étiquettes « Réactif » (70 % des réponses en 3 jours ou moins) et « Attentif » (50 %).	Jamais d'étiquette négative ; aucun badge embarquable sur un site tiers ; en dessous de trois dossiers répondus, aucun signal n'est affiché.
L'entreprise est identifiée avant de publier	CompanyVerificationService : format ICE 15 chiffres, rapprochement du nom, statuts de vérification ; assertCanPublish bloque la publication tant que l'entreprise n'est pas vérifiée.	Aucun appel à une API OMPIC payante ; la vérification documentaire reste décidée par un administrateur (PATCH /admin/organizations/{id}).
La communauté peut faire retirer une annonce	POST /offers/{id}/report et OfferReport ; à trois signalements traités, JobOfferService suspend l'offre (REPORT_SUSPEND_THRESHOLD = 3) ; l'administrateur rétablit ou écarte.	Le comptage est une alerte, pas une enquête : aucun outil de preuve, aucune indemnisation.
Une décision laisse une trace	application_status_history en append-only, timeline publique au dossier, motif de refus pris dans refusal_reason_catalog, first_decision_at rempli au premier refus.	La timeline n'expose pas le détail interne aux candidats : le payload est réservé aux recruteurs (R03).
L'aide automatique ne juge pas sur l'identité	R15 : les prompts ne reçoivent que compétences, intitulé et niveau ; R16 : aucun crédit IA débité si l'appel échoue ; score de compatibilité déterministe, sans API tierce (R08).	Aucun modèle n'est entraîné par HireLink ; les aides IA produisent des brouillons relus par un humain, jamais des décisions automatiques.

1.4 Périmètre technique observé

Tableau 1.3 — Couches livrées et volumétrie réelle du dépôt

Couche	Technologie	Volumétrie vérifiée dans le dépôt
API	Spring Boot 3.3, Java 21, Maven	21 contrôleurs REST, 154 endpoints sous /api/v1, 52 services, 36 classes de modèle dont 25 entités @Table et 11 énumérations.
Persistance	Spring Data JPA / Hibernate, MariaDB 10.4.32	base hirelink, hibernate.ddl-auto=update : 25 tables d'entités + la jointure job_offer_tags, soit 26 tables.
Interface	HTML, CSS et JavaScript sans framework	9 pages publiques (frontend/*.html), 18 pages applicatives (frontend/app/*.html), 55 fichiers JS écrits par le projet (trois bibliothèques tierces sont isolées dans js/vendor) et 21 fichiers CSS.
Sécurité	Spring Security 6, JWT, WebAuthn, TOTP	filtre JWT, cookie de rafraîchissement HttpOnly, CAPTCHA auto-hébergé, journal d'audit.
Exploitation	Deux processus locaux	API sur le port 8081, interface sur le port 5500 ; aucun conteneur, aucune infrastructure manquante pour la démonstration.

2. Objectifs et périmètre

2.1 Objectifs mesurables

Un objectif n'est retenu que s'il est vérifiable en exécutant l'application. La colonne « vérification » donne le geste à faire, la colonne « observation » donne ce qui doit être vu.

Tableau 2.1 — Objectifs du projet et preuve attendue

Réf	Objectif	Indicateur	Vérification	Observation de référence
GO-01	Publier une offre sans assistance	Temps de création d'une offre publiable	Compte recruteur → Offre nouvelle → Assistant en trois étapes → Publier.	Moins de dix minutes ; aucune correction manuelle en base.
GO-02	Traiter une candidature de bout en bout	Nombre de clics entre réception et décision	Pipeline, changement d'étape, motif de refus.	Une transition et une décision motivée par écran.
GO-03	Historiser toute décision	Une ligne par changement d'état	GET /applications/{id}/timeline après trois transitions.	Trois lignes, aucune modification possible des lignes précédentes.
GO-04	Interdire la décision sans motif	Taux de refus motivés	Passer un dossier en refus sans motif.	HTTP 400 « Choisissez un motif de refus. ».
GO-05	Isoler les organisations	Nombre d'accès inter-entreprises réussis	Appeler le pipeline d'une offre d'une autre organisation.	HTTP 403 « Hors organisation (R02) », ligne dans audit_logs.
GO-06	Rendre le rythme de réponse visible	Médiane de la première réponse affichée	Ouvrir la fiche d'une entreprise dont un recruteur a répondu à au moins trois dossiers.	Médiane en jours, étiquette Réactif ou Attentif le cas échéant.
GO-07	Bloquer les annonces à risque	Publications refusées sur contenu	Publier une offre reprenant une formule d'arnaque connue.	HTTP 403 « Publication refusée — contenu à risque (fake job)… ».
GO-08	Permettre l'exercice des droits RGPD	Export et effacement obtenus	GET /me/export puis POST /account/erase.	Fichier JSON téléchargé ; profil anonymisé effacé après revalidation.
GO-09	Coût d'usage nul pour démarrer	Prix des formules de base	GET /billing/plans, qui ne renvoie que les formules de l'audience du compte.	ESSENTIEL et ACCES à 0 dirham ; à 0 dirham de TTC la facture porte le statut OFFERTE, sinon REGLEE sans encaissement réel (limite de démonstration, voir section 2.3).

2.2 Ce qui est dans le périmètre

Tableau 2.2 — Modules spécifiés et références d'exigences

Module	Références	Nombre
Comptes, connexion et session	EF-01 à EF-11	11
Profil candidat et CV	EF-12 à EF-20	9
Découverte des offres (public)	EF-21 à EF-27	7
Candidature et pipeline	EF-28 à EF-38	11
Entretiens	EF-39 à EF-47	9
Organisation, équipe et collaboration	EF-48 à EF-55	8
Administration, modération et facturation	EF-56 à EF-64	9
Notifications et assistant IA	EF-65 à EF-75	11
Suivi d'entreprise et notifications en temps réel	EF-76 à EF-81	6

Total : 81 exigences fonctionnelles, 9 modules.

Volumétrie de référence de la base locale, comptée le 6 novembre 2026 dans le schéma hirelink et à recalculer avant la soutenance (les mêmes requêtes sont données ci-dessous) :

Tableau 2.4 — Volumétrie de démonstration mesurée

Grandeur	Valeur mesurée	Comment le revérifier
Comptes	126	SELECT COUNT(*) FROM users;
Candidats	29 dont 16 Junior, 9 Confirmé, 2 Stagiaire, 2 Senior	SELECT experience_level, COUNT(*) FROM users WHERE role='CANDIDAT' GROUP BY 1;
Organisations	42	SELECT COUNT(*) FROM organizations;
Organisations avec au moins une offre publiée	40	jointure organizations ↔ users.company ↔ job_offers.published
Offres	117 dont 106 publiées, 1 suspendue par la modération	SELECT published, COUNT(*) FROM job_offers GROUP BY 1;
Candidatures	217	SELECT COUNT(*) FROM applications;
Tables	26	SHOW TABLES;
Entreprises suivies	1 couple candidat-organisation	SELECT COUNT(*) FROM company_follows;

2.3 Ce qui n'est pas dans le périmètre

Cette section est volontairement longue. Elle écarte des fonctionnalités qui ont pu être annoncées dans une version antérieure du document, ou qui sont attendues dans un ATS du commerce. Rien de ce qui suit n'est implémenté, et rien de ce qui suit ne sera présenté comme acquis dans les sections 4 à 9.

Tableau 2.3 — Hors périmètre, statut et motif de la vérification

Élément	Statut	Vérification dans le dépôt
Paiement en ligne (carte, CMI, Stripe)	Non implémenté	Aucune dépendance de passerelle dans le POM ; POST /billing/subscribe émet seulement une ligne de facture, marquée REGLEE dès l'émission même pour une formule payante : la facture atteste une intention, pas un encaissement.
Envoi réel d'e-mails en démonstration locale	Non implémenté	hirelink.otp.log-to-console=true : les codes à usage unique sont écrits dans la console du serveur ; la table sent_emails journalise une file interne, consultée par GET /admin/emails.
Modèle d'IA entraîné ou affiné par HireLink	Non implémenté	Le fournisseur est un appel externe avec chaîne de repli (groq, gemini, mistral) ; aucun jeu de données client n'est exporté à cette fin.
Parrainage et liens de recommandation	Non implémenté	Ni table, ni route, ni vue ; la fonction F28 est barrée de docs/ACTEURS_FONCTIONNALITES_REGLES.md.
Check-list d'intégration d'un nouveau recruteur	Non implémenté	Aucune entité ni écran ; la mention figure uniquement dans la note de non-implémentation du document CDC_V4_THEORIE_VERS_CODE.md.
Badge de rythme embarquable sur un site d'entreprise	Non implémenté	Aucun point d'entrée iframe ou embarquable ; les signaux de rythme ne s'affichent que dans l'application.
Score ou étiquette de fiabilité du candidat	Non implémenté	Aucune table de type reliability_events ; l'application ne note pas les personnes.
Enquête NPS ou satisfaction après une candidature	Non implémenté	Fonction F20 retirée du document fonctionnel ; aucune route correspondante.
Promesse salariale en ligne et acceptation électronique	Non implémenté	Les étapes OFFER et HIRED de ApplicationStatus sont marquées dépréciées et ne figurent aucune transition autorisée : une embauche se conclut hors de la plateforme.
Accès jury externe à un dossier	Non implémenté	Aucune table d'invitation de jury ; l'évaluation reste réservée aux membres de l'organisation.
Plusieurs entretiens pour une même candidature	Non implémenté	Les données d'entretien sont des colonnes de la table applications : un seul créneau par dossier, reprogrammable mais non cumulable.

Entretien téléphonique programmable	Non implémenté	InterviewService.SCHEDULABLE = {ONSITE, VISIO} ; le type PHONE ne subsiste qu'en lecture pour les dossiers anciens.
Effet bloquant d'un critère éliminatoire de la grille d'évaluation	Non implémenté	Le booléen est stocké et affiché par ScorecardService, mais ApplicationService.advance ne consulte pas les critères : un veto n'arrête donc aucune transition.
Recherche, filtre et tri des offres côté serveur	Non implémenté	GET /offers/public renvoie la liste ouverte sans paramètre de recherche ; le filtrage est réalisé dans le navigateur.
API publique pour tiers et webhooks sortants	Non implémenté	Aucune route d'API publique, aucune signature sortante.
Application mobile native	Non implémenté	Interface responsive uniquement.
Produit multilingue (arabe, anglais)	Non implémenté	Les libellés sont en français, y compris les messages d'erreur.
Envois par SMS, WhatsApp ou notification push	Non implémenté	Canaux disponibles : notifications internes et flux SSE ; pas de passerelle externe.
Permissions sur mesure par utilisateur	Non implémenté	Trois rôles d'organisation fixes : OWNER, RECRUTEUR, HIRING_MANAGER.
Migrations versionnées (Flyway ou Liquibase)	Non implémenté	hibernate.ddl-auto=update ; database/schema.sql ne contient aucun CREATE TABLE.
Référence OpenAPI maintenue	Non implémenté	springdoc est dans les dépendances mais coupé par défaut (hirelink.swagger.enabled=${HIRELINK_SWAGGER_ENABLED:false}) ; la référence reste docs/API.md, tenue à la main.
Conteneurisation et déploiement automatisé	Non implémenté	Aucun Dockerfile ni docker-compose dans le dépôt.
Plan de reprise et sauvegarde chiffrée	Non traité	Hors du cadre d'un travail d'établissement ; aucune procédure décrite ou testée.
Compteur d'échecs de connexion persistant et multi-nœud	Non implémenté	AuthThrottle est en mémoire : un redémarrage ou un second nœud réinitialise le comptage.
Charge mesurée et test d'intrusion externe	Non réalisé	Listé comme limite connue dans docs/SECURITE.md ; seuls les contrôles fonctionnels de sécurité ont été exécutés.
Contrôle anti-discrétionnaire du score de compatibilité	Non implémenté	Le score est déterministe et explicable (section 5, R08), mais aucune étude statistique de biais n'a été conduite.
Garantie publique d'un délai de réponse au candidat	Non implémenté	Le délai promis par le recruteur est interne ; l'aide en ligne précise qu'aucun délai n'est promis ailleurs que par le rythme mesuré.
Règles R06, R07, R09 et R10	Sans correspondance dans le code	Aucune occurrence de ces références dans le backend ; elles sont retirées de la numérotation et ne sont donc pas revendiquées en section 5.
Types de notification « Décision » et « Pipeline »	Options de filtre jamais remplies	NotificationService n'écrit ni DECISION ni PIPELINE : ces deux options du filtre de app/notifications.html ne peuvent ramener aucune ligne. Elles sont signalées ici comme résiduelles, et non revendiquées comme une fonction.

3. Acteurs et personas

3.1 Rôles tels que définis dans le code

Deux niveaux de rôle coexistent : le rôle de compte (Role) décide de l'espace accessible, le rôle d'organisation (OrgRole) décide de ce qui est faisable dans l'espace d'une entreprise.

Tableau 3.1 — Rôles système et rôles d'organisation

Niveau	Valeur	Libellé affiché	Effet réel dans l'application
Role	CANDIDAT	Candidat	Espaces candidate-* ; POST /applications, GET /applications/mine, réponses d'entretien ; aucun droit d'écriture sur une offre.
Role	RECRUTEUR	Recruteur	Espaces recruiter-* ; crée des offres, une organisation, une équipe ; accès aux dossiers de son organisation seulement.
Role	ADMINISTRATEUR	Administrateur	Espace admin-* ; seul rôle à pouvoir écrire sur /api/v1/admin/**, vérification, offres et factures. Non proposé à l'inscription.
OrgRole	OWNER	Créateur	Gestion de l'équipe, invitations, formule d'abonnement, coordonnées ICE, transfert de propriété.
OrgRole	RECRUTEUR	Recruteur	Offres, pipeline, entretiens, grilles d'évaluation ; aucun droit sur l'équipe ni sur la formule.
OrgRole	HIRING_MANAGER	Responsable du poste	Accès limité aux dossiers auxquels il est assigné (applications.assigned_hm_user_id), lecture du pipeline, évaluation et proposition d'entretien ; ne gère pas les offres.

3.2 Personas

Tableau 3.2 — Six personas, besoins et fonctions concernées

Persona	Profil	Besoin	Fonctions mobilisées
Salma Berrada	Candidate, profil Junior, Tétouan, recherche un premier poste de développeuse	Postuler simplement, suivre l'état de chaque dossier, savoir si une entreprise répond vraiment.	EF-01, EF-02, EF-12, EF-13, EF-16, EF-21, EF-24, EF-28, EF-29, EF-31, EF-45, EF-67, EF-68, EF-76, EF-78, EF-80
Nadia Bennani	Créatrice de l'espace Atlas Digital (OWNER), entreprise vérifiée	Structurer l'équipe, maîtriser la formule et le nombre de sièges, répondre aux signalements.	EF-02, EF-10, EF-48, EF-49, EF-50, EF-51, EF-52, EF-59
Karim Benali	Recruteur membre de la même organisation	Publier et piloter ses propres offres sans se voir opposer le catalogue d'équipe.	EF-32, EF-33, EF-34, EF-35, EF-36, EF-38, EF-54, EF-55
Meriem Alaoui	Responsable du poste (HIRING_MANAGER), côté métier	Ne voir que les dossiers qui la concernent, évaluer sur des critères, proposer une rencontre.	EF-36, EF-37, EF-39, EF-40, EF-41
Youssef Cherkaoui	Administrateur de la plateforme	Contrôler la fraude, vérifier les entreprises, arbitrer les signalements, retrouver une décision dans le journal.	EF-27, EF-56 à EF-64
Visiteur sans compte	Intéressé par une annonce depuis un lien	Lire l'offre et l'entreprise sans s'inscrire, décider ensuite s'il crée un compte.	EF-21, EF-23, EF-25, EF-26

3.3 Droits réels par rôle

Tableau établi à partir des annotations de sécurité et des contrôles de service. « oui » signifie autorisé, « non » signifie refusé par le serveur, avec le message indiqué le cas échéant.

Tableau 3.3 — Matrice des droits (V = visiteur, C = candidat, M = recruteur membre, O = créateur, H = responsable du poste, A = administrateur)

Action	V	C	M	O	H	A	Refus serveur
Consulter les offres publiées	oui	oui	oui	oui	oui	oui	—
Consulter la fiche d'une organisation	oui	oui	oui	oui	oui	oui	—
Postuler à une offre	non	oui	non	non	non	non	403 « Réservé aux candidats »
Retirer sa candidature	non	oui	non	non	non	non	403 « Seul le candidat peut retirer (R11) »
Créer ou modifier une offre	non	non	oui	oui	non	oui	403 pour le responsable du poste (canManageOffer)
Publier une offre	non	non	oui	oui	non	oui	403 tant que l'entreprise n'est pas vérifiée
Gérer l'équipe et inviter	non	non	non	oui	non	non	403 « Seul le créateur de l'espace gère l'équipe (R13) »
Choisir la formule d'abonnement	non	oui (personnelle)	non	oui	non	non	403 « Seul le créateur de l'espace choisit la formule »
Voir tous les dossiers de l'organisation	non	non	oui	oui	non	oui	—
Voir un dossier de pipeline	non	non	oui	oui	assigné	oui	403 « Dossier non assigné (R14) »
Noter sur la grille d'évaluation	non	non	oui	oui	assigné	non	403 « HM : dossier non assigné (R14) »
Planifier un entretien	non	non	oui	oui	assigné	non	403 « HM : dossier non assigné (R14) »
Répondre à une proposition d'entretien	non	oui (son dossier)	non	non	non	non	403
Signaler une offre	oui	oui	non	non	non	non	403 « Réservé aux candidats » (POST /offers/{id}/report)
Suivre une entreprise et recevoir ses nouvelles offres	non	oui	non	non	non	non	403 « Réservé aux candidats » (POST /follows/{organizationId})
Voir combien de candidats suivent son entreprise	non	non	oui	oui	oui	oui	—
Suspendre ou rétablir une offre	non	non	non	non	non	oui	403 « Accès refusé. » hors /admin
Journal d'audit et export CSV	non	non	non	non	non	oui	403 « Accès refusé. »
Gérer le catalogue de motifs de refus	non	non	non	non	non	oui	403 « Réservé à l'administration »
Exporter ses données personnelles	non	oui	oui	oui	oui	oui	—

3.4 Comptes de démonstration

Tableau 3.4 — Comptes semés par config/DataSeeder.java

Rôle de démonstration	Identifiant	Mot de passe	Particularité vérifiée
Candidat	candidat@hirelink.ma	Candidat123!	Alias miroir du compte Salma Berrada, même hash de mot de passe.
Recruteur	recruteur@hirelink.ma	Recruteur123!	Alias miroir d'un compte recruteur.
Administrateur	admin@hirelink.ma	Admin123!	Youssef Cherkaoui, accès à /api/v1/admin/**.
Créatrice d'entreprise	n.bennani@atlasdigital.ma	Recruteur123!	Nadia Bennani, OWNER d'Atlas Digital, ICE 001544289000035, entreprise vérifiée, formule ACCES.

Recruteur membre	k.benali@atlasdigital.ma	Recruteur123!	Membre RECRUTEUR de la même organisation, sans droit d'équipe.
Responsable du poste	m.alaoui@atlasdigital.ma	Recruteur123!	OrgRole HIRING_MANAGER, accès filtré par R14.

4. Exigences fonctionnelles

Quatre-vingt-et-une exigences, regroupées en neuf modules. La colonne « preuve observable » indique ce que le professeur voit à l'écran ; la colonne « implémentation » donne la route REST ou la page qui la sert. Aucune exigence de cette liste ne décrit une fonction absente du dépôt : les fonctions non réalisées sont nommées en section 2.3.

Tableau 4.0 — 81 exigences fonctionnelles numérotées EF-01 à EF-81

4.1 Comptes, connexion et session

Réf	Exigence	Preuve observable	Implémentation
EF-01	Créer un compte candidat ou recruteur par e-mail, avec code de vérification reçu	Écran « Créer un compte », puis saisie du code à 6 chiffres	POST /auth/request-otp, POST /auth/verify-register-otp
EF-02	Se connecter par mot de passe	Jeton rendu, page d'accueil de l'espace correspondant au rôle	POST /auth/login
EF-03	Se connecter par code envoyé par e-mail (sans mot de passe)	Le compte sans mot de passe reçoit un code et entre	POST /auth/request-otp, POST /auth/verify-login-otp
EF-04	Se connecter avec Google	Bouton Google ; le compte se crée ou se rattache par `google_sub`	POST /auth/google
EF-05	Se connecter par passkey (WebAuthn)	Clé enregistrée puis réutilisée sur le même navigateur	POST /auth/passkey/enroll/options, /finish puis /auth/passkey/login/options, /finish
EF-06	Double authentification TOTP avec codes de secours	Page Sécurité : activation, QR, 8 codes de secours affichés une fois	POST /account/mfa/setup, /mfa/enable, /mfa/backup-codes
EF-07	Exiger un CAPTCHA après deux échecs de connexion	Épreuve image + question affichées au troisième essai	POST /auth/captcha (l'image est rendue par le serveur)
EF-08	Mot de passe oublié et réinitialisation en un seul usage	Lien à usage unique ; le second usage est refusé	POST /auth/forgot-password, POST /auth/reset-password
EF-09	Renouveler le jeton sans re-saisir le mot de passe	Navigation continue après expiration du jeton d'accès	POST /auth/refresh (cookie HttpOnly)
EF-10	Voir et révoquer ses sessions et appareils	Liste avec IP, étiquette d'appareil, dernière activité	GET /account/sessions, DELETE /account/sessions/{id}
EF-11	Se désinscrire : désactiver le compte ou effacer ses données (RGPD)	Deux actions distinctes, message de confirmation	POST /account/deactivate, POST /account/erase

4.2 Profil candidat et CV

Réf	Exigence	Preuve observable	Implémentation
EF-12	Compléter son profil (identité, ville, disponibilité, expérience)	Formulaire unique, jauges de complétion	PATCH /me
EF-13	Choisir son niveau d'expérience dans une liste fermée	Le serveur refuse un libellé hors liste	PATCH /me — RG-09
EF-14	Déclarer compétences, langues et recherches	Suggestion de compétences pendant la saisie	GET /skills/suggest
EF-15	Préférences de contrat et de lieux	Filtres pré-remplis sur la liste des offres	PATCH /me, GET /catalog/places
EF-16	Importer un CV (PDF ou image) et l'analyser	Le texte est extrait puis proposé en sections éditables	POST /ocr/cv
EF-17	Valider section par section le CV importé	Assistants de tri : compétences, expériences, langues	POST /skills/classify, PATCH /me
EF-18	Conserver le CV d'origine et sa version stockée	Deux champs distincts : nom affiché, nom de fichier disque	backend/data/cvs
EF-19	Joindre un nouveau CV à une candidature précise	Choix « Nouveau CV » dans l'assistant de candidature	POST /applications/{id}/cv
EF-20	Exporter l'intégralité de ses données personnelles	Fichier JSON téléchargeable	GET /me/export

4.3 Découverte des offres (public)

Réf	Exigence	Preuve observable	Implémentation
EF-21	Consulter les offres publiées sans compte	Grille des offres avec ville, contrat, salaire	GET /offers/public
EF-22	Filtrer par ville, contrat, mode de travail, niveau, compatibilité	Compteur du panneau = nombre de lignes réellement affichées	app/candidate.html
EF-23	Rechercher en texte libre	Résultats instantanés sur titre, ville, compétences	filtrage exécuté dans le navigateur sur la liste renvoyée par GET /offers/public
EF-24	Voir le détail d'une offre et son score de compatibilité	Décomposition du score (compétences demandées / présentes)	GET /offers/{id}
EF-25	Consulter la vitrine publique d'une entreprise	Logo, badge de vérification, offres en ligne, présentation	GET /organizations/public/company
EF-26	Parcourir l'annuaire des entreprises	Recherche par nom, ville, secteur	GET /organizations/public
EF-27	Signaler une offre abusive	La fiche offre bascule en quarantaine après seuil de signalements	POST /offers/{id}/report

4.4 Candidature et pipeline

Réf	Exigence	Preuve observable	Implémentation
EF-28	Postuler en une seule action, lettre et CV inclus	Message explicite si la candidature existe déjà	POST /applications — RM01
EF-29	Suivre l'avancement de ses candidatures	Statut, date de première décision, échéance de réponse	GET /applications/mine
EF-30	Retirer sa candidature	Statut WITHDRAWN, dossier grisé dans le pipeline recruteur	PATCH /applications/{id}/status (status = WITHDRAWN)
EF-31	Voir la frise d'un dossier	Chaque changement d'étape avec auteur et horodatage	GET /applications/{id}/timeline
EF-32	Recruteur : voir tous les dossiers d'une offre	Table triable, isolation d'organisation appliquée	GET /applications/by-offer/{id}
EF-33	Recruteur : faire avancer une candidature d'une étape	Le pipeline et le compteurs se remettent à jour	PATCH /applications/{id}/status
EF-34	Recruteur : refuser avec un motif choisi dans un catalogue	Le motif est obligatoire et enregistré	PATCH /applications/{id}/status avec rejectionReason, GET /refusal-reasons
EF-35	Recruteur : rédiger le motif de refus avec l'aide IA	Brouillon généré, modifiable avant envoi	POST /ai/refusal-draft
EF-36	Shortlist et scorecard par critère	Critères définis par offre, notes par évaluateur	GET/PUT /offers/{offerId}/scorecard-criteria, GET/POST /applications/{appId}/scorecard
EF-37	Attribuer un responsable de poste (hiring manager)	Le dossier devient visible pour cette personne	PATCH /applications/{id}/assign-hm
EF-38	Recruteur : mesurer son rythme de réponse réel	Indicateur de retard affiché sur le pipeline	GET /applications/pace

4.5 Entretiens

Réf	Exigence	Preuve observable	Implémentation
EF-39	Planifier un entretien sur site ou en visioconférence	Adresse obligatoire en sur site, lien obligatoire en visio	PUT /applications/{id}/interview — RG-04
EF-40	Choisir la nature de l'entretien (RH, technique, manager…)	Libellé affiché au candidat	PUT /applications/{id}/interview
EF-41	Choisir le fuseau horaire et la durée	Quatre fuseaux acceptés, durée par défaut 45 minutes	PUT /applications/{id}/interview — RG-05
EF-42	Reporter un entretien	La réponse du candidat est remise à zéro	PUT /applications/{id}/interview
EF-43	Annuler un entretien avec une raison	Le candidat est notifié de l'annulation	POST /applications/{id}/interview/cancel
EF-44	Candidat : confirmer, refuser ou proposer un créneau	Réponse enregistrée, vue par l'équipe	POST /applications/{id}/interview/answer

EF-45	Candidat : ajouter l'entretien à son calendrier	Fichier .ics téléchargé, ou 404 si aucun entretien	GET /applications/{id}/interview.ics
EF-46	Rappel automatique la veille de l'entretien	Une seule relance par entretien	InterviewReminderService
EF-47	Agenda d'équipe avec post-it personnels	Regroupement par jour, notes persistées	app/recruiter-agenda.html

4.6 Organisation, équipe et collaboration

Réf	Exigence	Preuve observable	Implémentation
EF-48	Créer l'organisation depuis un compte recruteur	Créateur devient OWNER	GET /organizations/mine (ensureForRecruiter crée l'espace) — RG-01
EF-49	Renseigner et vérifier l'ICE	Badge « Identité vérifiée » sur la vitrine publique	POST /organizations/mine/ice/check, POST /organizations/mine/verify
EF-50	Inviter un membre par e-mail	Lien d'invitation, compte rattaché à l'organisation	POST /organizations/mine/invite, POST /organizations/invitations/{token}/accept
EF-51	Promouvoir un membre ou transférer la propriété	Deux actions distinctes, tracées dans le journal	PATCH /organizations/mine/members/{userId}/role, PATCH .../ownership
EF-52	Suspendre et rétablir un membre	Le membre suspendu perd l'accès à l'espace entreprise	PATCH /organizations/mine/members/{userId}/suspend, PATCH .../reinstate
EF-53	Notes internes et fil d'événements de l'organisation	Journal horodaté des actions de l'équipe	GET /organizations/mine/events
EF-54	Gérer les offres de son organisation (publier, clôturer, archiver)	Chaque action a un effet visible sur la liste	POST /offers/{id}/publish, /close, /archive (et /reopen, /unarchive, /unpublish)
EF-55	Prolonger la date limite d'une offre	Nouvelle date contrôlée côté serveur	POST /offers/{id}/extend

4.7 Administration, modération et facturation

Réf	Exigence	Preuve observable	Implémentation
EF-56	Modérer les offres signalées (suspendre, rétablir, dépublier)	File d'attente des signalements, décision tracée	POST /admin/offers/{id}/suspend, /restore, /unpublish
EF-57	Gérer les comptes (activer, suspendre, rechercher)	Table des 126 comptes avec filtre	GET /admin/users, PATCH /admin/users/{id}/active
EF-58	Gérer les organisations et leurs logos	Logo absent = initiales, aucune image cassée	GET /admin/organizations, PATCH /admin/organizations/{id}
EF-59	Gérer les plans commerciaux et les factures	Une formule change les crédits IA et les sièges, rien d'autre	GET /admin/plans, /admin/invoices
EF-60	Gérer le catalogue des motifs de refus	Ajout, renommage, retrait d'un motif	GET/POST /refusal-reasons
EF-61	Consulter statistiques, graphiques et consommation IA	Entonnoir plateforme, crédits consommés par fonction	GET /admin/stats, /admin/charts, /admin/ai-usage
EF-62	Consulter les e-mails réellement envoyés et leur statut	Statut et erreur par destinataire, aucune promesse non tenue	GET /admin/emails
EF-63	Rechercher transversalement candidats, offres et entreprises	Une seule barre, résultats groupés	GET /admin/search?q=
EF-64	Consulter et exporter le journal d'audit	Filtre par type d'action, export CSV	GET /admin/audit

4.8 Notifications et assistant IA

Réf	Exigence	Preuve observable	Implémentation
EF-65	Recevoir une notification interne à chaque événement de son dossier	Centre de notifications, badge non lu	GET /notifications, NotificationService
EF-66	Être redirigé vers l'élément concerné depuis une notification	Le lien ouvre la page et met le focus sur la ligne	app/notifications.html + data-focus
EF-67	Demander une réécriture	Texte proposé, jamais appliqué sans	POST /ai/profile-rewrite

	professionnelle de son profil	validation	
EF-68	Se préparer à un entretien (questions attendues)	Kit d'entretien généré pour l'offre choisie	POST /ai/interview-kit
EF-69	Expliquer un score de compatibilité	Compétences manquantes listées avec les libellés du catalogue	POST /ai/match-explain
EF-70	Faire relire un texte (orthographe et ton)	Corrections proposées avant envoi	POST /ai/language-check
EF-71	Consulter son solde de crédits IA	Coût par appel, solde restant, historique du mois	GET /ai/credits
EF-72	Préparer un entretien : questions attendues et repères de réponse	Depuis « Mes candidatures », l'aide se genère pour l'offre concernée	POST /ai/interview-prep
EF-73	Récupérer une grille d'entretien pour un poste (recruteur)	Questions rangées par thème, modifiables avant usage	POST /ai/interview-kit
EF-74	Synthétiser un CV en quelques lignes	Depuis le profil candidat et depuis l'assistant recruteur	POST /ai/cv-summary
EF-75	Se faire conseiller par le coach IA sur son profil	Réponse à une question libre, appuyée sur le CV déposé	POST /ai/coach

4.9 Suivi d'entreprise et notifications en temps réel

Réf	Exigence	Preuve observable	Implémentation
EF-76	Suivre une entreprise depuis sa fiche publique	Le bouton « Suivre » devient « Vous suivez » ; un second clic ne crée pas de doublon	POST /follows/{organizationId} — contrainte unique sur le couple (candidat, organisation)
EF-77	Consulter la liste des entreprises que l'on suit et s'en désabonner	Liste et compteur cohérents, retrait immédiat	GET /follows, DELETE /follows/{organizationId}
EF-78	Être prévenu quand une entreprise suivie publie une offre	Une notification de type « Suivi » par candidat qui suit, jamais deux pour la même offre	CompanyFollowService.announceNewOffer, appelé par JobOfferService à la publication (kind FOLLOW, notification interne seule)
EF-79	Compter les candidats qui suivent son entreprise (recruteur)	Le compteur de la fiche « Entreprise & équipe » vient de la table company_follows	GET /organizations/mine → followerCount
EF-80	Recevoir une notification sans rafraîchir la page	La cloche et le badge se mettent à jour pendant que l'onglet reste ouvert	POST /notifications/stream-ticket puis GET /notifications/stream (flux SSE)
EF-81	Filtrer son centre de notifications par type	Une ligne « Tous les types », puis un intitulé français par type	app/notifications.html ; kinds réellement écrits par le serveur : APPLICATION, FOLLOW, STATUS, INTERVIEW, SLA, ASSIGN, SYSTEM, MODERATION, HIRED (dossiers historiques), INFO (repli)

5. Règles de gestion

Chaque règle est écrite dans le service nommé, pas seulement dans l'interface : un appel direct à l'API est soumis aux mêmes contrôles qu'une navigation. Les messages cités sont ceux renvoyés par le serveur, relevés pendant les tests.

5.1 Règles portant l'identifiant écrit dans le code

Les références R01 à R16 et RM01 sont celles des commentaires et des messages du dépôt : les rechercher dans le code ramène à la ligne qui applique la règle.

Tableau 5.1 — 13 règles identifiées dans le code

Réf	Règle	Effet vérifié / message serveur	Où elle est codée
R01	Machine d'états du pipeline : les transitions autorisées sont déclarées une seule fois (SUBMITTED → SCREENING ou REJECTED, SCREENING → SHORTLISTED ou REJECTED, SHORTLISTED → INTERVIEW ou REJECTED, INTERVIEW → REJECTED).	Une transition hors table est un 400 motivé ; OFFER et HIRED n'apparaissent dans aucune transition nouvelle.	ApplicationService (TRANSITIONS)
R02	Isolation par organisation : un recruteur ne voit et ne pilote que les offres et les dossiers de son organisation.	403 « Aucune organisation (R02) » pour un recruteur hors organisation, « Hors organisation (R02) » sur le dossier d'un autre espace ; 403 puis 200 vérifiés en test sur /applications/by-offer.	OrganizationService.requireMembership / assertSameOrg
R03	La frise d'un dossier n'est pas un écran public : elle est réservée aux personnes qui ont droit au dossier.	403 « Accès historique refusé (R03) ».	CatalogPrivacyController.timeline
R04	Un refus porte un motif pris dans le catalogue (code, par exemple PROFILE_MISMATCH).	400 « Choisissez un motif de refus. » si le motif est absent, « Choisissez un motif de la liste. » s'il est hors catalogue ; first_decision_at est rempli au premier refus.	ApplicationService.applyRefusalCatalog
R05	Checklist à trois points du dossier, pré-cochée seulement quand la donnée existe déjà.	Badge « x / 3 » ; une case pré-cochée est étiquetée Auto, jamais validée à la place du recruteur.	frontend/js/recruiter-pipeline.js
R08	Le score de compatibilité est calculé localement : aucune API tierce, aucun crédit IA consommé.	Un appel de matching retire 0 crédit, visible dans /ai/credits.	SkillMatchingService
R11	Retirer une candidature n'appartient qu'au candidat.	403 « Seul le candidat peut retirer (R11) », 400 « Retrait impossible à cette étape (R11) ».	ApplicationService.advance
R12	La frise est append-only : on ajoute une ligne, on n'en modifie aucune.	application_status_history ne reçoit aucun UPDATE dans le code ; trois transitions = trois lignes.	model/ApplicationStatusHistory
R13	Seul le créateur de l'espace gère l'équipe.	403 « Seul le créateur de l'espace gère l'équipe (R13) », « Seul le créateur de l'espace peut le transférer », « Seul le créateur de l'espace choisit la formule ».	OrganizationService
R14	Un responsable de poste ne voit que les dossiers qui lui sont attribués.	403 « Dossier non assigné (R14) », « HM : dossier non assigné (R14) » ; filtrage par assigned_hm_user_id.	OrganizationService.assertCanAccessApplication
R15	Les prompts d'aide automatique ne contiennent aucune donnée d'identité.	Le prompt ne reçoit que compétences, intitulé du poste et niveau ; ni nom, ni e-mail, ni téléphone.	AiAssistController, HttpLlmProvider, LocalLlmProvider
R16	Un crédit IA est débité seulement après un appel réussi.	Ledger ai_usage_logs ; en cas d'échec le solde ne bouge pas.	AiCreditService, AiAssistController
RM01	Une seule candidature par couple candidat / offre.	409 « Candidature déjà existante (RM01) » ; une candidature retirée peut être rouverte, un doublon sur un dossier actif non.	ApplicationService.apply

5.2 Règles de gestion sans identifiant dans le code

Ces règles sont réellement appliquées par le serveur, mais le dépôt ne les nomme pas par une référence Rxx. Elles reçoivent ici une référence RG-nn, qui est une référence de ce document et non du code : c'est écrit pour qu'aucune référence inventée ne passe pour une référence du dépôt.

Tableau 5.2 — 12 règles référencées par le document seul

Réf	Règle	Effet vérifié / message serveur	Où elle est codée
RG-01	Le créateur de l'organisation en devient le propriétaire (OWNER) ; promotion d'un membre et transfert de propriété sont deux actions distinctes et journalisées.	Membership.orgRole = OWNER posé à la création de l'espace.	OrganizationService.createOwned
RG-02	Un dossier déjà refusé ou retiré n'est pas rejouable.	Le passage d'un dossier WITHDRAWN à une autre étape est un 400 motivé.	ApplicationService.advance
RG-03	Un dossier n'est planifiable en entretien que s'il est à l'étape INTERVIEW.	400 « Ce dossier n'est pas à l'étape entretien. »	ApplicationService.interviewApplication
RG-04	Un entretien est sur site ou en visioconférence : adresse obligatoire dans le premier cas, lien obligatoire dans le second.	400 « Indiquez l'adresse de l'entretien. » / « Indiquez le lien de visioconférence. »	InterviewService.schedule
RG-05	Le fuseau horaire d'un entretien appartient à une liste fermée de quatre valeurs.	400 « Fuseau horaire non pris en charge. » pour une valeur hors liste (Mars/Phobos testé).	InterviewService (ZONES)
RG-06	Un créneau d'entretien ne peut pas être dans le passé.	400 « Le créneau d'entretien est dans le passé. »	InterviewService.schedule
RG-07	Reporter un entretien remet à zéro la réponse du candidat.	interview_confirmation repasse à PENDING : l'invitation redevient « en attente ».	InterviewService.schedule
RG-08	Le rappel d'entretien de la veille part une seule fois.	interview_reminder_sent passe à true et n'est plus re-déclenché.	InterviewReminderService
RG-09	Le niveau d'expérience d'un profil appartient à la liste du formulaire.	400 « Niveau d'expérience hors liste : Stagiaire, Junior, Confirmé, Senior, Lead, Manager ».	MeController
RG-10	Une offre signalée au-delà du seuil est suspendue d'office et sort de la recherche publique.	quarantine_reason = SUSPENDED_BY_REPORTS, seuil REPORT_SUSPEND_THRESHOLD = 3.	JobOfferService
RG-11	Tout échec remonte un statut HTTP et un corps JSON portant uniquement le champ message en français ; le front affiche ce message, jamais un texte inventé.	49 statuts attendus sur 49 retrouvés, 101 assertions sans échec (run newman du 6 novembre 2026).	config/GlobalExceptionHandler
RG-12	Un candidat ne suit une entreprise qu'une seule fois, et la publication d'une offre ne notifie chaque follower qu'une seule fois.	Contrainte unique sur le couple (candidate_user_id, organization_id) ; un second clic sur « Suivre » reste sans effet et sans doublon de notification.	model/CompanyFollow, CompanyFollowService.announceNewOffer

6. Exigences non fonctionnelles

Trente-quatre exigences, chacune avec le moyen qui a servi à la vérifier. Une exigence non fonctionnelle n'est recevable que si elle est mesurée ou observée ; les mesures citées viennent du run newman du 6 novembre 2026.

6.1 Sécurité des accès

Réf	Exigence	Vérification
EN-01	Jeton JWT court, cookie de rafraîchissement HttpOnly, session double expiration (inactivité et durée absolue).	UserSession.idleExpiresAt / absoluteExpiresAt
EN-02	Autorisation par rôle sur chaque route (@PreAuthorize) et par organisation dans le service.	403 sur /admin/stats avec un jeton candidat (testé)
EN-03	Politique de mot de passe au serveur, hash bcrypt, jamais en clair ni en log.	security/PasswordPolicy
EN-04	Anti-robot : CAPTCHA après deux échecs, limitation du nombre de tentatives par IP et compte.	AuthThrottle, RateLimitFilter
EN-05	En-têtes de sécurité sur toutes les réponses, dont Content-Security-Policy et X-Content-Type-Options.	SecurityHeadersFilter (relevés dans les réponses newman)
EN-06	Échappement systématique des valeurs injectées dans le DOM ; aucune concaténation HTML brute des données serveur.	js/ui.js + audits de lot 50
EN-07	Journaux d'audit horodatés sur les actions sensibles (connexion, refus, export, décision d'offre) avec IP et agent.	AuditService, GET /admin/audit

6.2 Données et conformité

Réf	Exigence	Vérification
EN-08	Export complet des données personnelles en un appel.	GET /me/export
EN-09	Deux niveaux d'effacement : désactivation réversible ou effacement définitif.	POST /account/deactivate, POST /account/erase
EN-10	Purge périodique des données mortes (tokens, sessions, corbeille).	RetentionService
EN-11	Aucune colonne inutile : les tables mortes ont été supprimées, les colonnes lues sont toutes affichées quelque part.	lot F — nettoyage base
EN-12	Un seul vocabulaire par colonne : le serveur refuse un libellé hors liste.	RG-09

6.3 Performance et robustesse

Réf	Exigence	Vérification
EN-13	Toutes les réponses de la suite lecture seule arrivent en moins de 4 secondes ; moyenne mesurée 193 ms, pire cas 1 733 ms.	docs/postman/resultat-lecture-seule.md
EN-14	Requêtes indexées sur les chemins chauds (offres publiées, candidatures par offre, sessions par utilisateur).	contraintes et index JPA
EN-15	Aucune exception non gérée : tout échec remonte un statut HTTP explicite.	GlobalExceptionHandler
EN-16	L'application démarre sans infrastructure externe : l'e-mail et l'IA sont optionnels.	--spring.mail.host= ; LocalLlmProvider sans clé

6.4 Ergonomie et interface

Réf	Exigence	Vérification
EN-17	Interface entièrement en français, messages à la première personne, ton sobre.	copies relues page par page
EN-18	Un compteur de filtre annonce le nombre de lignes réellement affichées.	lot 52
EN-19	Les dates sont calculées dans le fuseau local de l'utilisateur, pas en UTC.	lot 53
EN-20	États à données zéro dessinés, jamais un tableau vide ni un « 0 » trompeur.	lot 54
EN-21	Navigation clavier complète : focus rendu après modale, piégeage dans les voiles, intitulés explicites.	lots 59 et 60

EN-22	Reprise après session expirée : l'utilisateur revient sur la page voulue après reconnexion.	lot 57
EN-23	Aucune promesse de visibilité ou de délai non mesurable ; les badges reflètent un fait compté.	lot 34
EN-24	Images 100 % locales : logos ENSA, université et HireLink servis depuis le dépôt.	frontend/assets

6.5 Exploitation

Réf	Exigence	Vérification
EN-25	Deux processus suffisent : API sur 8081, interface statique sur 5500.	docs/API.md
EN-26	Schéma créé par Hibernate (ddl-auto=update) ; le script SQL n'est plus la référence.	26 tables, 4 seulement dans database/schema.sql
EN-27	Données de démonstration reproductibles par DataSeeder (comptes, organisations, offres).	config/DataSeeder
EN-28	Les secrets ne sortent pas du poste : clés d'API dans application-local.properties (gitignored), sauvegarde de base exclue du dépôt.	.gitignore
EN-29	Consommation IA visible : coût par appel, solde, historique mensuel.	GET /ai/credits

6.6 Qualité et testabilité

Réf	Exigence	Vérification
EN-30	Une collection Postman complète (73 requêtes) et une collection lecture seule (49) rejouables sans abîmer la base de démonstration.	docs/postman
EN-31	Le run lecture seule est exécuté en ligne de commande (newman) et son résultat est archivé.	resultat-lecture-seule.json
EN-32	Les routes mortes sont retirées du code puis vérifiées 404, pas masquées côté front.	GET /auth/me, GET /ai/status
EN-33	Le code retiré est déplacé et documenté, jamais détruit silencieusement.	docs/dead-code
EN-34	Chaque exigence de ce document est reliée à un fichier du dépôt (section 9).	matrice de traçabilité

7. Modèle de données

Vingt-six tables dans le schéma `hirelink`. Vingt-cinq correspondent aux entités JPA et sont créées par Hibernate au premier démarrage (ddl-auto=update) ; la vingt-sixième, job_offer_tags, est la table de jointure générée par l'annotation ManyToMany. Le fichier database/schema.sql ne décrit que quatre tables et n'est plus la référence : cette divergence est assumée et notée ici plutôt que masquée.

Tableau 7.1 — Les 26 tables, leur entité et ce qu'elles portent

Table	Entité JPA	Créée par	Contenu
users	User	Hibernate	comptes, rôles, profil candidat, MFA, formule
organizations	Organization	Hibernate	entreprise, ICE, logo, présentation
memberships	Membership	Hibernate	appartenance à une organisation + OrgRole
notifications	InAppNotification	Hibernate	notifications internes avec lien profond
job_offers	JobOffer	Hibernate	offre, cycle de vie, quarantaine, SLA de réponse
applications	Application	Hibernate	candidature, statut, entretien, CV, échéances
application_status_history	ApplicationStatusHistory	Hibernate	frise : chaque changement d'étape
scorecard_criteria	ScorecardCriterion	Hibernate	critères de décision d'une offre
scorecard_entries	ScorecardEntry	Hibernate	note et commentaire par évaluateur
refusal_reason_catalog	RefusalReason	Hibernate	catalogue des motifs de refus
offer_reports	OfferReport	Hibernate	signalements candidats, seuil de suspension
tags	Tag	Hibernate	étiquettes d'offre
job_offer_tags	jointure JobOffer ↔ Tag	Hibernate	table de liaison many-to-many
organization_events	OrganizationEvent	Hibernate	fil d'événements de l'équipe
organization_notes	OrganizationNote	Hibernate	notes internes par organisation
organization_invitations	OrganizationInvitation	Hibernate	invitations en attente
company_follows	CompanyFollow	Hibernate	candidats qui suivent une entreprise, couple unique
billing_invoices	BillingInvoice	Hibernate	factures et avoirs
commercial_plans	CommercialPlan	Hibernate	formules : crédits IA et sièges uniquement
sent_emails	SentEmail	Hibernate	e-mails réellement envoyés et leur statut
email_otps	EmailOtp	schema.sql puis Hibernate	codes de connexion et de vérification
password_reset_tokens	PasswordResetToken	Hibernate	jetons de réinitialisation à usage unique
user_sessions	UserSession	Hibernate	sessions, révocations, appareils
webauthn_credentials	WebAuthnCredential	Hibernate	passkeys
audit_logs	AuditLog	Hibernate	journal d'audit des actions sensibles
ai_usage_logs	AiUsageLog	Hibernate	consommation IA par fonction et fournisseur

7.1 Énumérations

Tableau 7.2 — Les 11 énumérations du domaine et leur colonne

Enum	Valeurs	Colonne	Règle liée
Role	CANDIDAT, RECRUTEUR, ADMINISTRATEUR	users.role	trois espaces, aucune valeur intermédiaire
OrgRole	OWNER, RECRUTEUR, HIRING_MANAGER	memberships.org_role	droits d'équipe, distincts du rôle global
ApplicationStatus	SUBMITTED, SCREENING, SHORTLISTED, INTERVIEW, REJECTED, WITHDRAWN (+ OFFER, HIRED historiques)	applications.status	R01 (transitions), RG-02 (statuts terminaux)
ContractType	CDI, CDD, Stage, PFE, PFA, Stage d'été, Alternance, Freelance, Temps partiel	job_offers.contract_type	vocabulaire du catalogue
WorkMode	ONSITE, HYBRID, REMOTE	job_offers.work_mode	filtre « mode de travail »
ExperienceLevel	NONE, JUNIOR, INTERMEDIATE, SENIOR, EXPERT	job_offers.experience_level	niveau demandé par l'offre
EducationLevel	BAC, BAC_2, BAC_3, BAC_4, BAC_5, DOCTORATE	job_offers.education_level	diplôme demandé
CompensationType	PAID, UNPAID, NEGOTIABLE, UNSPECIFIED	job_offers.compensation_t	rémunération

		ype	
PayPeriod / PayBasis	HOUR, DAY, MONTH, YEAR / GROSS, NET	job_offers.salary_period, salary_basis	fourchette affichée
PlanTier	ESSENTIEL, PERFORMANCE, ACCES, PREMIUM	users.plan_tier	change crédits IA et sièges, rien d'autre
SentEmail.Status	SENT, FAILED, LOGGED	sent_emails.status	statut réel de l'envoi, affiché sans promesse non tenue

7.2 Vocabulaires contrôlés

Un vocabulaire contrôlé est une liste que le serveur connaît. Là où le front seul filtrait, la vérification a été déplacée côté serveur : un appel direct à l'API est maintenant soumis à la même liste qu'un formulaire.

Tableau 7.3 — Listes fermées et endroit où elles sont imposées

Vocabulaire	Valeurs admises	Source d'interface	Contrôle serveur
Niveau d'expérience d'un profil	Stagiaire, Junior, Confirmé, Senior, Lead, Manager	select « pf-level »	MeController refuse tout autre libellé (RG-09)
Fuseau horaire d'un entretien	Africa/Casablanca, Europe/Paris, Europe/London, UTC	liste ZONES	InterviewService.schedule (RG-05)
Nature d'entretien	RH, TECHNIQUE, MANAGER, COMPÉTENCES, PROJET, CONTRE-RÉFÉRENCE	KIND_FR	InterviewService.schedule
Type d'entretien	ONSITE, VISIO	SCHEDULABLE	adresse ou lien obligatoire selon le type (RG-04)
Motif de refus	catalogue administrable	table refusal_reason_catalog	GET /refusal-reasons, géré par l'administrateur
Type de notification interne	APPLICATION, FOLLOW, STATUS, INTERVIEW, SLA, ASSIGN, SYSTEM, MODERATION, HIRED, INFO	colonne notifications.kind	NotificationService ; le centre de notifications filtre sur ces types
Source d'e-mail	SECURITY et ACCOUNT obligatoires, APPLICATION et INTERVIEW réglables	MailService.Kind	un e-mail non obligatoire part seulement si l'interrupteur du compte est actif

8. Parcours fonctionnels

Six parcours complets, chacun avec le point d'observation et la capture correspondante de la série v5 (docs/guide-captures/v5-2026-11-06). Les comptes indiqués sont ceux semés par DataSeeder.

Tableau 8.1 — Six parcours, du clic à la preuve

Réf	Parcours	Compte	Déroulé	Ce qui prouve la règle	Captures
P-01	Découverte et candidature	candidat@hirelink.ma	Accueil → offres → filtre ville → détail (score 71 %) → Postuler (lettre + CV) → « Candidature envoyée » → Mes candidatures.	Un second clic sur Postuler renvoie « Candidature déjà existante (RM01) » (RM01).	11-candidat-offres.png, 12-candidat-detail-offre.png, 13-candidat-mes-candidatures.png
P-02	Tri d'un pipeline	recruteur@hirelink.ma	Pipeline → colonne Reçues → ouvrir un dossier → Présélection → Shortlist.	Les quatre compteurs du haut de page bougent exactement du nombre de lignes déplacées (EN-18).	21-recruteur-pipeline.png, 23-recruteur-candidats.png
P-03	Refus motivé	recruteur@hirelink.ma	Dossier → Refuser → choisir un motif → message rédigé → valider.	Sans motif la demande est refusée ; la date de première décision est enregistrée et sert au calcul du rythme de réponse (R04, EF-38).	21-recruteur-pipeline.png
P-04	Planification d'un entretien	recruteur@hirelink.ma puis candidat@hirelink.ma	Entretiens → planifier (nature, type, date, fuseau, adresse ou lien) → le candidat reçoit l'invitation → confirme → ajoute l'entretien au calendrier.	Un fuseau hors liste et le serveur répond « Fuseau horaire non pris en charge. » (RG-05) ; un report remet la réponse du candidat à zéro (RG-07).	24-recruteur-entretiens.png, 15-candidat-notifications.png
P-05	Vie d'équipe	n.bennani@atlasdigital.ma	Entreprise & équipe → inviter un membre → le promouvoir → transférer la propriété → noter un événement.	Le créateur reste le seul à pouvoir transférer ; chaque action laisse une ligne dans le journal d'audit (RG-01).	26-recruteur-equipe.png, 25-recruteur-agenda.png
P-06	Modération et pilotage	admin@hirelink.ma	À traiter → offres signalées → rétablir ou suspendre → entreprises (vérification ICE) → comptes → plans → audit.	La fiche publique d'une entreprise suspendue disparaît de la recherche ; l'audit exporte la décision.	32-admin-moderation.png, 31-admin-entreprises.png, 33-admin-audit.png

9. Matrice de traçabilité

Chaque ligne relie une exigence à l'endroit exact du dépôt où elle est écrite. Le chemin et le numéro de ligne sont produits par une recherche du marqueur dans les sources au moment de la génération du document : ils ne sont pas recopiés à la main et suivent donc le code. Une ligne « marqueur introuvable » signifie que la preuve doit être reprise, pas que la fonction manque forcément.

Tableau 9.1 — 50 exigences tracées, 0 marqueur(s) à reprendre

Réf	Exigence	Fichier:ligne (calculé)	Marqueur cherché
EF-02	connexion par mot de passe et jeton	backend/src/main/java/ma/ensat/hirelink/controller/AuthController.java:95	@PostMapping("/login")
EF-01	inscription par code reçu	backend/src/main/java/ma/ensat/hirelink/controller/AuthController.java:83	@PostMapping("/verify-register-otp")
EF-06	double authentification TOTP	backend/src/main/java/ma/ensat/hirelink/controller/AccountController.java:75	@PostMapping("/mfa/setup")
EF-07	CAPTCHA après deux échecs	backend/src/main/java/ma/ensat/hirelink/security/AuthThrottle.java:17	AuthThrottle
EF-10	sessions actives et révocation	backend/src/main/java/ma/ensat/hirelink/controller/AccountController.java:50	@GetMapping("/sessions")
EF-11	export et effacement RGPD	backend/src/main/java/ma/ensat/hirelink/controller/AccountController.java:125	@PostMapping("/erase")
EF-13 / RG-09	liste fermée des niveaux d'expérience	backend/src/main/java/ma/ensat/hirelink/controller/MeController.java:36	EXPERIENCE_LEVELS
EF-16	analyse de CV	backend/src/main/java/ma/ensat/hirelink/controller/OcrController.java:29	@PostMapping(value = "/cv"
EF-21	liste publique des offres	backend/src/main/java/ma/ensat/hirelink/controller/JobOfferController.java:23	@GetMapping("/public")
EF-25	vitrine publique d'entreprise	backend/src/main/java/ma/ensat/hirelink/controller/OrganizationController.java:87	@GetMapping("/public/company")
EF-76 / RG-12	suivre une entreprise, un seul couple	backend/src/main/java/ma/ensat/hirelink/model/CompanyFollow.java:13	columnNames = {"candidate_user_id", "organization_id"}
EF-76	route de suivi	backend/src/main/java/ma/ensat/hirelink/controller/CompanyFollowController.java:16	@RequestMapping("/api/v1/follows")
EF-78	notification des followers à la publication	backend/src/main/java/ma/ensat/hirelink/service/CompanyFollowService.java:97	announceNewOffer
EF-79	compteur des candidats qui suivent	backend/src/main/java/ma/ensat/hirelink/controller/OrganizationController.java:363	"followerCount"
EF-80	flux temps réel SSE	backend/src/main/java/ma/ensat/hirelink/controller/NotificationController.java:42	@GetMapping(value = "/stream"
EF-72	préparation d'entretien par l'assistant	backend/src/main/java/ma/ensat/hirelink/controller/AiAssistController.java:82	@PostMapping("/interview-prep")
EF-73	grille d'entretien par l'assistant	backend/src/main/java/ma/ensat/hirelink/controller/AiAssistController.java:103	@PostMapping("/interview-kit")
EF-74	synthèse de CV	backend/src/main/java/ma/ensat/hirelink/controller/AiAssistController.java:152	@PostMapping("/cv-summary")
EF-75	coach IA	backend/src/main/java/ma/ensat/hirelink/controller/AiAssistController.java:195	@PostMapping("/coach")
EF-27 / RG-10	signalement et seuil de suspension	backend/src/main/java/ma/ensat/hirelink/service/JobOfferService.java:460	SUSPENDED_BY_REPORTS
EF-28 / RM01	anti-doublon de candidature	backend/src/main/java/ma/ensat/hirelink/service/ApplicationService.java:122	Candidature déjà existante
EF-30	retrait de candidature	backend/src/main/java/ma/ensat/hirelink/service/ApplicationService.java:272	req.status() == ApplicationStatus.WITHDRAWN
EF-31	frise du dossier	backend/src/main/java/ma/ensat/hirelink/controller/CatalogPrivacyController.java:42	@GetMapping("/applications/{id}/timeline")
EF-32 / R02	isolation par organisation	backend/src/main/java/ma/ensat/hirelink/service/ApplicationService.java:517	assertCanAccessApplication

EF-34 / R04	refus avec motif	backend/src/main/java/ma/ensat/hirelink/service/ApplicationService.java:311	applyRefusalCatalog(app, req.rejectionReason())
EF-36	scorecard par critère	backend/src/main/java/ma/ensat/hirelink/controller/ScorecardController.java:24	@GetMapping("/offers/{offerId}/scorecard-criteria")
EF-38	rythme de réponse mesuré	backend/src/main/java/ma/ensat/hirelink/controller/ApplicationController.java:49	@GetMapping("/pace")
EF-39 / RG-04	adresse ou lien obligatoire	backend/src/main/java/ma/ensat/hirelink/service/InterviewService.java:60	Indiquez le lien de visioconférence
EF-41 / RG-05	fuseaux acceptés	backend/src/main/java/ma/ensat/hirelink/service/InterviewService.java:42	ZONES = Set.of
EF-42 / RG-07	report qui remet la réponse à zéro	backend/src/main/java/ma/ensat/hirelink/service/InterviewService.java:74	app.setInterviewConfirmation(PENDING)
EF-45	export .ics	backend/src/main/java/ma/ensat/hirelink/controller/ApplicationController.java:102	@GetMapping("/{id}/interview.ics")
EF-46 / RG-08	rappel J-1 une seule fois	backend/src/main/java/ma/ensat/hirelink/service/InterviewReminderService.java:24	fixedDelayString = "${hirelink.interview.reminder-poll-ms
EF-49	vérification de l'ICE	backend/src/main/java/ma/ensat/hirelink/controller/OrganizationController.java:269	@PostMapping("/mine/ice/check")
EF-51	transfert de propriété	backend/src/main/java/ma/ensat/hirelink/controller/OrganizationController.java:328	@PatchMapping("/mine/members/{userId}/ownership")
EF-56	modération d'offre	backend/src/main/java/ma/ensat/hirelink/controller/AdminController.java:382	@PostMapping("/offers/{id}/suspend")
EF-59	plans commerciaux	backend/src/main/java/ma/ensat/hirelink/controller/AdminController.java:561	@GetMapping("/plans")
EF-62	e-mails réellement envoyés	backend/src/main/java/ma/ensat/hirelink/controller/AdminEmailController.java:20	@RequestMapping("/api/v1/admin/emails")
EF-64	journal d'audit	backend/src/main/java/ma/ensat/hirelink/controller/AdminController.java:177	@GetMapping("/audit")
EF-65	notifications internes et badge non lu	backend/src/main/java/ma/ensat/hirelink/controller/NotificationController.java:30	@GetMapping
EF-66	lien profond jusqu'à l'élément concerné	frontend/js/app-shell.js:595	querySelectorAll("[data-focus]")
RG-11	message d'erreur unique	backend/src/main/java/ma/ensat/hirelink/config/GlobalExceptionHandler.java:36	GlobalExceptionHandler
EN-18	compteur de filtre = lignes affichées	frontend/js/candidate-home.js:162	filter-summary
EN-19	date locale, pas UTC	backend/src/main/java/ma/ensat/hirelink/service/BusinessTime.java:10	class BusinessTime
R03	frise réservée aux ayants droit	backend/src/main/java/ma/ensat/hirelink/controller/CatalogPrivacyController.java:55	Accès historique refusé (R03)
R04	motif de refus obligatoire	backend/src/main/java/ma/ensat/hirelink/service/ApplicationService.java:378	Choisissez un motif de refus.
R05	checklist à trois points du dossier	frontend/js/recruiter-pipeline.js:689	hl-checklist-v2
R11	retrait réservé au candidat	backend/src/main/java/ma/ensat/hirelink/service/ApplicationService.java:274	Seul le candidat peut retirer (R11)
R12	frise append-only	backend/src/main/java/ma/ensat/hirelink/model/ApplicationStatusHistory.java:6	Timeline immuable F13 / R12
R15	prompt IA sans donnée d'identité	backend/src/main/java/ma/ensat/hirelink/controller/AiAssistController.java:64	R15 : compétences / rôles / niveau uniquement
R16	crédit IA débité après succès seulement	backend/src/main/java/ma/ensat/hirelink/controller/AiAssistController.java:266	R16 : débit seulement si succès

10. Planning, risques, limites et glossaire

10.1 Avancement par séance

Tableau 10.1 — Ce qui a été fait, dans l'ordre des séances

Séance	Livré	Vérifié par
1	Produit existant, audit des écrans et des promesses non tenues	relecture page par page, retrait des promesses de visibilité
2	Architecture commentée, contrat front/back, routes et champs	inventaire des 154 endpoints et des 27 pages
3	Rôles d'entreprise, cycle de vie des offres, modération administrateur	tests manuels + collection Postman
4	Crédits IA visibles, CAPTCHA serveur, badges sobres	GET /ai/credits, POST /auth/captcha
5	Nettoyage de la base de démonstration, schéma mort supprimé	26 tables, plus aucune table morte
6	Documentation : cahier des charges, diagrammes, captures, tests	le présent document, docs/diagrammes/v5, docs/postman

10.2 Risques et réponses

Tableau 10.2 — Risques identifiés, impact et parade déjà en place

Réf	Risque	Impact	Réponse en place
RQ-01	Le mot de passe racine de la base locale sert aussi en production	compromission des données	profil prod avec variables d'environnement, jamais de mot de passe dans le dépôt
RQ-02	Les clés d'API IA se retrouvent dans le code	coût et fuite de secret	application-local.properties gitignored, statut masqué dans l'interface
RQ-03	Le schéma diverge entre Hibernate et database/schema.sql	base incohérente au déploiement	documenté en section 7 ; la référence est l'entité JPA
RQ-04	Une règle écrite seulement dans le navigateur est contournable	données corrompues	déplacement des contrôles côté serveur (RG-05, RG-09)
RQ-05	Le vocabulaire du front et celui du serveur diffèrent	lignes illisibles en base	liste fermée serveur + message qui rappelle le vocabulaire
RQ-06	Un e-mail promis n'est pas envoyé (SMTP local désactivé)	promesse non tenue	table sent_emails avec le statut réel, affichage de ce statut
RQ-07	La base de démonstration est abîmée pendant les tests	présentation faussée	collection lecture seule séparée, aucune écriture métier
RQ-08	Une offre de test reste visible publiquement	crédibilité	purge systématique après sonde, vérification par requête avant soutenance
RQ-09	Le CAPTCHA bloque une démonstration	écran bloqué	limitation en mémoire, réinitialisée au redémarrage
RQ-10	Une fonction annoncée n'existe pas	perte de confiance	section 2.3 « hors périmètre » assumée, matrice de traçabilité section 9

10.3 Limites assumées

Ces limites ne sont pas des oublis : elles sont écrites pour que la soutenance ne promette pas ce que le logiciel ne fait pas.

- HireLink ne remplace pas la décision d'embauche : la promesse finale (contrat, salaire, prise de poste) vit dans l'entreprise, hors plateforme. Les statuts OFFER et HIRED ne sont plus atteignables.
- Le paiement en ligne n'est pas branché : les factures sont un registre administratif, pas un encaissement.

- La vérification d'identité d'entreprise s'appuie sur le format et la cohérence de l'ICE, pas sur un appel officiel à la DGI.
- L'analyse de CV dépend d'un fournisseur d'IA quand une clé est configurée ; sans clé, un repli local plus simple prend le relais.
- Aucune application mobile : l'interface est responsive dans un navigateur.
- Le stockage des fichiers est local (backend/data) ; une migration objet n'est pas implémentée.

10.4 Glossaire

Tableau 10.3 — Termes utilisés dans ce document

Terme	Sens retenu ici
ATS	Applicant Tracking System : logiciel qui suit les candidatures d'une entreprise.
ICE	Identifiant Commun de l'Entreprise marocain, quinze chiffres ; servi par la plateforme comme preuve d'existence légale.
Pipeline	Colonnes d'étapes d'une candidature : Reçues, Présélection, Shortlist, Entretien.
Scorecard	Grille de critères et de notes remplie par les évaluateurs après un entretien.
SLA de réponse	Délai que l'entreprise s'engage à tenir pour répondre à une candidature ; mesuré, pas promis.
Hiring manager	Responsable du poste, membre de l'équipe qui ne voit que les dossiers qui lui sont attribués.
Formule (plan)	Abonnement : il change le nombre de crédits IA et de sièges, jamais la visibilité des offres.
Crédit IA	Unité de consommation d'un appel à un modèle de langage, comptée par fonction.
Passkey	Clé WebAuthn stockée dans le navigateur ou le système, sans mot de passe.
Totp	Code à six chiffres à durée limitée, produit par une application d'authentification.
DataSeeder	Classe qui remplit la base de démonstration au premier démarrage.
newman	Exécuteur en ligne de commande de collections Postman.